

Cairo University — Faculty of Computing and Artificial Intelligence

Graduation Project — Appendix A: Initial Proposal

Section 1 — Project Identification

Project Information

Field	Value
Project Title	Thaghrawy — An AI-Powered Autonomous Penetration Testing Assistant (based on the Model Context Protocol)
Department(s)	Information Technology
Academic Year	2025–2026
Semester of Registration	Semester 1
Project Category	Data Science & AI (Applied AI / Cybersecurity)

Team Members (Min. 4, Max. 6)

#	Name	ID	Program	Email
1	Loay Ahmed Badea	20220259	IT	—
2	Youssef Ali Mohamed	20230644	IT	—
3	Yehia Mohamed Othman	20230646	IT	—

#	Name	ID	Program	Email
4	Mohamed Abd El- Nasser	20220295	IT	—
5	Omar Ayman Mesbah	20220223	IT	—
6	Belal Mohamed Youness	20220087	IT	—

Supervision

Role	Details
Primary Supervisor	Prof. Haitham S. Hamza — Department of Information Technology
Co-Supervisor	—
Teaching Assistant	—
External Sponsor / Company	—

Section 2 — Project Description

Motivation and Problem Statement

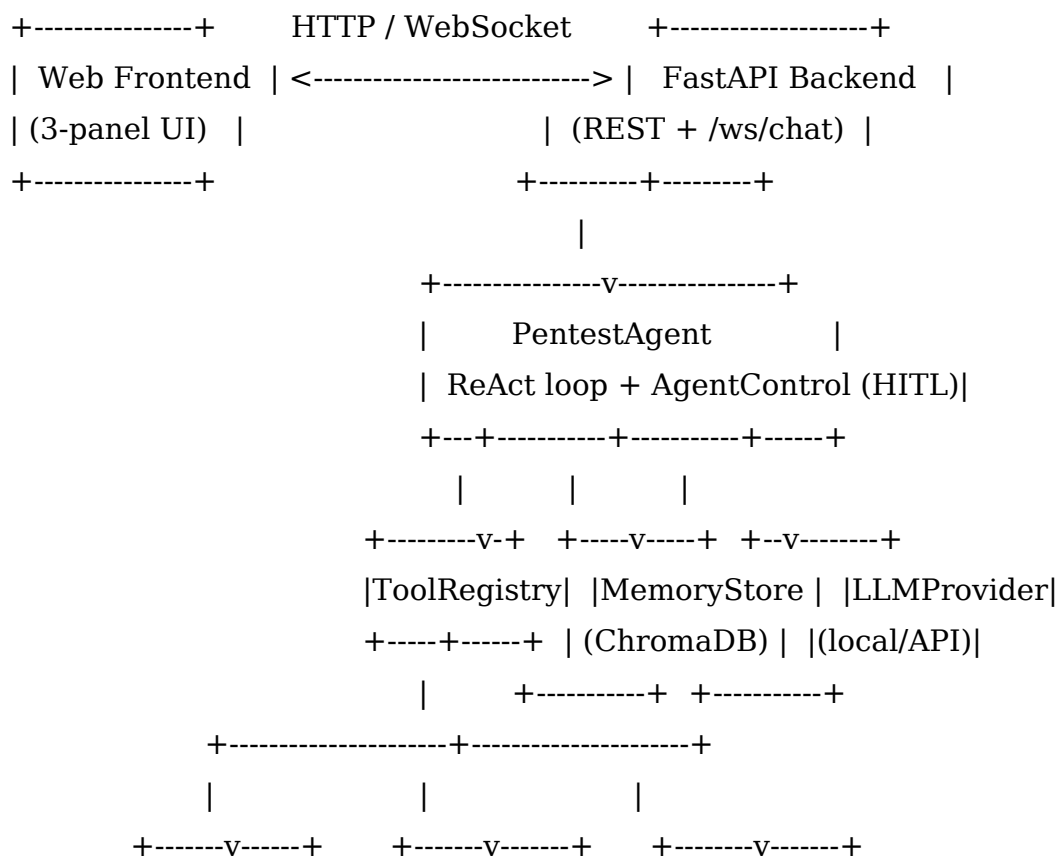
Penetration testing is one of the most effective defences against cyber-attacks, yet it is expensive, time-consuming, and heavily dependent on individual expertise, while the global security-skills gap continues to widen. Existing AI-assisted tools fall into two camps: *passive advisors* (e.g. PentestGPT) that only guide a human who still runs every tool by hand, and *closed-source autonomous platforms* (e.g. XBOW) that are inaccessible to the research community. Meanwhile, most integrations between Large Language Models and security tools are ad-hoc and non-standard. There is a clear need for an **open, standardised, transparent** framework in which

an AI agent can orchestrate real security tools, reason about their output, remember past engagements, and keep a human safely in control.

Proposed Solution / Project Objective

Thaghrawy is an open-source AI penetration-testing assistant. It wraps professional security tools as **Model Context Protocol (MCP)** servers so any MCP-compatible LLM can invoke them through a standard interface. A ReAct-style agent autonomously reconnoitres a target, interprets tool output, and persists findings to a **semantic memory** store for cross-engagement recall. The engagement runs in phases: the agent enumerates autonomously and auto-ingests easy findings, then hands off to a **human-in-the-loop** collaboration mode where every tool call can be approved, rejected, or edited. Finally it produces two reports — a technical report (CVSS + reproduction) and an executive report (DREAD + business impact). Objectives: reduce assessment time, lower the expertise threshold, keep humans in control, and turn each engagement into reusable knowledge (and fine-tuning data).

Initial High-Level System Architecture (overview)



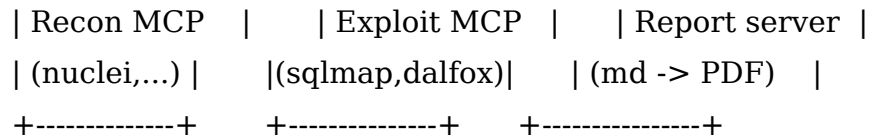


Figure A.1 — Conceptual architecture (to be replaced with a drawn diagram).

Key Technologies and Tools

Python 3, FastAPI, the MCP SDK; ChromaDB + sentence-transformers (all-MiniLM-L6-v2) for semantic memory; local/remote LLMs via a multi-provider abstraction (LM Studio / Anthropic / OpenAI-compatible / Ollama); Docker & Docker Compose; wrapped security tools including nmap, nuclei, subfinder, amass, httpx, ffuf, gobuster, sqlmap, nikto, dalfox, wapiti, hydra; pytest for testing; xhtml2pdf for report rendering.

Stakeholders and Beneficiaries

Security analysts and penetration testers; small and medium organisations that cannot afford large red teams; security educators and students; the open-source security community (reproducible, non-black-box tooling).

Potential Industry Partners or ICT Companies

Not applicable at this stage (open-source academic prototype).

Section 3 — Project Plan

#	Task Title	Description	Responsible	Target Week
1	Requirements & architecture	Study MCP, select stack, design architecture	All	W2, Sem 1
2	LLM provider abstraction	Anthropic / OpenAI / Ollama behind	—	W4, Sem 1

#	Task Title	Description	Responsible	Target Week
		one interface		
3	Tool registry + recon wrappers	Register first recon MCP tools	—	W5, Sem 1
4	Semantic memory	ChromaDB store + local embeddings	—	W6, Sem 1
5	Engagement lifecycle	JSON persistence + session logs	—	W7, Sem 1
6	API + WebSocket + frontend	FastAPI REST, streaming chat, UI	—	W9, Sem 1
7	Expand tool coverage	~29 recon + exploit tools (incl. dalfox, wapiti)	All	W11, Sem 1
8	DREAD + FR-01 mode toggle	Risk scoring; recon-only vs full-analysis	—	W13, Sem 1
9	Dual PDF reports	Technical + executive report generation	—	W14, Sem 1
10	Human-in-the-loop system	Approval gate, phased workflow, curation	All	Sem 2
11	Training-data export	SFT + DPO preference pairs	—	Sem 2

#	Task Title	Description	Responsible	Target Week
12	Benchmark runs (ESR/AST/FP/D etection)	Live evaluation vs DVWA / Juice Shop	All	Sem 2
13	Final documentation + poster	50–70 pp document, A0 poster	All	W13, Sem 2

Section 4 — Declarations and Signatures

We, the undersigned, declare that the information provided in this proposal is accurate and that we commit to adhering to the Unified Graduation Project Bylaws of the Faculty of Computers and Artificial Intelligence, Cairo University.

Student Signatures

- Student 1: _____
- Student 2: _____
- Student 3: _____
- Student 4: _____
- Student 5: _____
- Student 6: _____

Supervisor Approval — Name: Prof. Haitham S. Hamza Signature: _____ Date: _____

Department Head Endorsement — Signature: _____ Date: _____